

Clase 069 — Reconocimiento activo

Parte: 3 — Hacking ético y pentesting: metodología · Fuente: *Nmap Network Scanning* (G. Lyon) y *Penetration Testing* (G. Weidman) 🕒 Duración estimada: 110 min · Nivel: Intermedio

Objetivo

Descubrir hosts vivos, puertos abiertos, servicios y versiones interactuando directamente con el objetivo mediante escaneo. El reconocimiento activo, sobre todo con **nmap**, convierte el mapa OSINT en una lista precisa de superficies atacables.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Descubrir** hosts vivos con barridos ICMP/ARP y `nmap -sn`.
- 2. **Escanear** puertos TCP/UDP con distintas técnicas (SYN, connect, UDP).
- 3. **Detectar** servicios y versiones con `-sV` y sistema operativo con `-O`.
- 4. **Ejecutar** scripts NSE para enumeración específica.
- 5. **Ajustar** el timing y la evasión para equilibrar sigilo y velocidad.

Temas

#	Tema	Por qué importa
1	Descubrimiento de hosts	Reduce el ruido escaneando solo lo vivo
2	SYN scan vs. connect scan	Sigilo y privilegios distintos
3	Escaneo UDP	Servicios críticos (DNS, SNMP) viven en UDP
4	Detección de versión <code>-sV</code>	La versión determina qué exploits aplican
5	Nmap Scripting Engine (NSE)	Automatiza enumeración y detección
6	Timing y evasión (<code>-T</code> , <code>--scan-delay</code>)	Evitar IDS o no tumbar servicios frágiles
7	Guardado de resultados (<code>-oA</code>)	Trazabilidad para el informe

Definiciones y características

- **SYN scan (`-sS`)**: envía SYN y no completa el handshake. Característica clave: rápido y relativamente sigiloso; requiere privilegios de root.
- **Connect scan (`-sT`)**: completa el three-way handshake vía la pila del SO. Característica clave: no necesita root pero es más ruidoso y lento.
- **Detección de versión (`-sV`)**: interroga banners para identificar producto y versión. Característica clave: base para mapear CVEs.

- **NSE:** motor de scripts Lua de nmap. Característica clave: categorías como `default`, `safe`, `vuln`, `auth` para tareas concretas.
- **Escaneo UDP (`-sU`):** sondea puertos UDP. Característica clave: lento por la ausencia de respuestas; imprescindible para SNMP/DNS.
- **Timing templates (`-T0` – `-T5`):** presets de velocidad. Característica clave: `-T4` es un buen equilibrio; `-T0/-T1` para evasión.

Herramientas y preparación

```
sudo apt install -y nmap masscan
nmap --version
```

Monta un laboratorio aislado: Kali como atacante y **Metasploitable 2/3** o una VM propia como objetivo, en una red host-only sin salida a Internet.

 **Nota ética:** el escaneo activo **sí** genera tráfico y puede ser detectado o considerado hostil. Ejecútalo únicamente contra tus propias máquinas de laboratorio o dentro de un alcance autorizado por escrito. Escanear IPs de terceros sin permiso puede ser ilegal.

Laboratorio guiado

Sustituye `TARGET` por la IP de tu VM vulnerable (por ejemplo `192.168.56.101`).

1. Descubre hosts vivos en el segmento:

```
bash sudo nmap -sn 192.168.56.0/24
```

2. Escaneo SYN rápido de los 1000 puertos comunes:

```
bash sudo nmap -sS -T4 TARGET
```

3. Escaneo completo de todos los puertos TCP:

```
bash sudo nmap -sS -p- -T4 TARGET -oA full_tcp
```

4. Detección de versión y SO sobre los puertos abiertos:

```
bash sudo nmap -sV -O -p 21,22,80,139,445 TARGET
```

5. Escaneo UDP de servicios clave:

```
bash sudo nmap -sU -p 53,161,137 TARGET
```

6. Enumeración con NSE (categoría default + safe):

```
bash sudo nmap -sC -p 21,80,445 TARGET
```

7. Guarda todo en los tres formatos para el informe:

```
bash sudo nmap -sS -sV -p- -oA recon_TARGET TARGET
```

Ejercicios

1. Explica por qué `-sS` requiere root y `-sT` no.
2. Compara el tiempo de un escaneo `-T2` frente a `-T4` sobre el mismo objetivo.
3. Usa NSE para obtener el título HTTP de un servidor web (`--script http-title`).
4. Escanea solo los puertos UDP 53 y 161 e interpreta los estados `open|filtered` .
5. Genera salida `-oA` y localiza el archivo `.gnmap` : ¿para qué sirve?
6. Diseña un comando de escaneo sigiloso con `--scan-delay` y `-T1` .

Reto verificable

Produce un **inventario de servicios** de tu VM objetivo: lista de puertos abiertos TCP y UDP, servicio, versión y sistema operativo estimado, guardado con `-oA` .

Criterio de aceptación: el inventario incluye al menos cinco puertos abiertos con su versión (`-sV`), un intento de detección de SO y los ficheros de salida `.nmap` , `.gnmap` y `.xml` presentes en disco.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"You requested a scan type which requires root"	Usa <code>sudo</code> o cambia a <code>-sT</code>
Todos los puertos aparecen <code>filtered</code>	Firewall o host equivocado; verifica ruta y estado del host
Escaneo UDP eterno	Es normal; limita puertos con <code>-p</code> y usa <code>--host-timeout</code>
<code>-O</code> no acierta el SO	Pocos puertos abiertos; añade <code>-sV</code> y <code>--osscan-guess</code>
Detectan el escaneo al instante	<code>-T5</code> es muy ruidoso; baja a <code>-T2</code> y usa <code>--scan-delay</code>

Preguntas frecuentes

 **¿masscan reemplaza a nmap?** No. `masscan` es ultrarrápido para descubrir puertos abiertos en rangos enormes, pero `nmap` es superior en detección de versión y NSE. Se combinan: `masscan` para descubrir, `nmap` para profundizar.

 **¿Por qué a veces un puerto sale `open|filtered` ?** Es típico en UDP: `nmap` no recibe respuesta y no puede distinguir si está abierto o filtrado. Usa scripts o `-sV` para confirmar.

 **¿El escaneo puede tumbar un servicio?** Sí, servicios frágiles (impresoras, SCADA, dispositivos IoT) pueden caer con escaneos agresivos. Baja el timing y coordínalo con el cliente si están en alcance.

 **¿Qué scripts NSE son seguros?** Las categorías `safe` y `default` evitan acciones intrusivas. Evita `intrusive` , `exploit` o `brute` salvo que el RoE lo permita.

Referencias

- Lyon, G. *Nmap Network Scanning* — <https://nmap.org/book/>
- Nmap NSE — <https://nmap.org/nsedoc/>
- Weidman, G. *Penetration Testing*, cap. de escaneo (No Starch Press, 2014).
- masscan — <https://github.com/robertdavidgraham/masscan>

Siguiente clase

Clase 070 - Enumeracion: SMB, SNMP, SMTP y LDAP